

ISO 27001:2022 - TOP 20 AUDIT CONTROLS

A.5 – Organisational Controls (Top 8)

<u>Control #</u>	<u>Control Name</u>	<u>Why It Is Checked So Often</u>
A.5.1	Policies for Information Security	Auditors always check if policies exist, are approved, and are reviewed annually.
A.5.16	Identity Management	Auditors check if you manage the full lifecycle of user access (hire, move, fire)
A.5.19	Supplier Relationships	Auditors check if you assess third party vendors
A.5.24	Incident Mangement Planning	Auditors check if you have plan for handling security incidents
A.5.25	Assessment of security Events	Auditors check if you actually log and review security events
A.5.27	Information Security Continuity	Auditors check if you have a business continuity plan
A.5.29	Information Security Continuity	Auditors check if you test your continuity plan (e.g. Disaster Drill)
A.5.30	ICT Readiness for Business Continuity	Auditors check if your IT systems are ready to support business continuity.

A.6 People Controls (TOP 3)

<u>Control #</u>	<u>Control Name</u>	<u>Why It Is Checked So Often</u>
A.6.3	Information Security Awareness	Auditors always check if employees receive security training and phishing simulations
A.6.4	Diciplinary Process	Auditors check if there is a process for handling employees who violate security policies
A.6.6	Remote Working	Auditors check if remote work is secure (VPN, MFA. Locked Screens)

A.7 Physical Controls (TOP 3)

<u>Control #</u>	<u>Control Name</u>	<u>Why It Is Checked So Often</u>
A.7.1	Physical Security Perimeter	Auditors check if the office and server room are physically secured
A.7.2	Physical Entry Controls	Auditors check if visitors sign in and are escorted
A.7.8	Equipment Sitting & Protection	Auditors check if servers are in locked racks and equipment is secured

A.8 Technological Controls (TOP 6)

<u>Control #</u>	<u>Control Name</u>	<u>Why It Is Checked So Often</u>
A.8.5	Secure Authenticaion	Auditors check if MFA is enforced or all admin accounts
A.8.7	Protection Against Malware	Auditors check if Antivirus and endpoint protection are install and updated
A.8.8	Management of Technical Vulnerabilities	Auditors check if you patch systems regularly (e.g. Monthly patching)
A.8.13	Information Backup	Auditors check if back up are performed, stored offsite and tested.
A.8.15	Logging	Auditors check if you log access and changes to systems
A.8.16	Monitorin Activiteis	Auditors check if you actively monitor logs for suspicious activities.